SOC: monitoreo, registros e incidentes

2 de octubre de 2026

Objetivo y puestos

Observar accesos y actividad, relacionar video con registros y coordinar una respuesta. SOC no modifica cuentas o tarjetas sin solicitarlo al área responsable.

SOC tiene cinco puestos: coordinación, monitoreo de entrada, monitoreo interior y móvil, consulta de registros y respuesta a incidentes. Cada puesto usa un identificador genérico en las evidencias públicas.

Laptop SOC 1: video. SOC 2: registros e incidentes. No necesitan instalar un sistema adicional de análisis: el hub puede mostrar las fuentes en ventanas separadas.

Paso 1. Preparar el puesto

1. Conectar ambas laptops a la red acordada.
2. Abrir el NVR en SOC 1 con una cuenta de consulta, no administrador.
3. Comprobar cámaras entrada/interior y recuperación de video.
4. Abrir en SOC 2 el CSV del lector, la aplicación de registros y exportaciones OneLogin/Microsoft.
5. Crear carpeta de evidencias y copiar Plantillas/incidentes.csv.
6. Confirmar con TI que las horas están sincronizadas.

La hora de Frigate en carpetas de grabación puede estar en UTC y la vista del navegador en hora local. Conservar zona horaria en el registro del incidente; el CSV RFID incluye ambas. No comparar una hora UTC con otra local como si fueran iguales.

Paso 2. Consultar fuentes

RFID

Pedir a Seguridad Física una copia actualizada de eventos_rfid.csv o acceso de lectura al registro. Verificar UID, resultado, empleado y entrada/salida. La lectura es un evento de autorización; confirmar cruce real con video.

Si SOC usa Ubuntu y recibió la copia:

```
tail -n 20 eventos_rfid.csv
```

Para seguimiento de un archivo local que el operador actualiza:

```
tail -f eventos_rfid.csv
```

Una copia descargada no se actualiza automáticamente. No describir ese comando como integración en tiempo real si el archivo no se comparte ni sincroniza.

Aplicación

Iniciar sesión por OneLogin con lab_role=auditor y abrir /registros. La aplicación devuelve los últimos 100 eventos: SCIM_CREATE, SCIM_UPDATE, LOGIN_ONELOGIN, acciones permitidas/denegadas y LOGOUT_APP.

Guardar una exportación después de cada ensayo. La cuenta auditora puede leer, pero no ejecutar mantenimiento o administración. Los fallos que ocurren antes de volver de OneLogin se consultan también en OneLogin: no todos aparecen como login local.

OneLogin

IAM abre Activity/Events y Users → Provisioning según las opciones del tenant. Filtrar por usuario y periodo. SOC conserva capturas o exportaciones con: evento, usuario, hora, resultado y aplicación. Distinguir intento de login, asignación de rol y creación/suspensión de cuenta de aplicación.

Microsoft 365

TI entrega registros de auditoría/inicio de sesión de Entra y, cuando aplique, registros Microsoft 365/Purview y vistas de amenazas. Una creación de usuario y un acceso a un documento son actividades distintas; no mezclar sus fuentes.

Paso 3. Relacionar un recorrido

Elegir LAB-INGENIERO y registrar:

Fuente	Qué buscar
RRHH	Cuenta, puesto y autorización aprobada
RFID	UID de LAB-INGENIERO, entrada permitida y hora
Cámara entrada	Persona presenta tarjeta y cruza
OneLogin	Inicio de sesión y MFA del usuario
Aplicación	Mantenimiento permitido
Cámara interior	Persona trabaja en la estación
Aplicación	Cierre de sesión
RFID/cámara	Salida registrada y persona saliendo

Guardar IDs de pruebas y archivos en Plantillas/pruebas.csv. No afirmar que existe un panel automático que relaciona todas las fuentes: en este montaje la correlación es manual mediante identidad y hora.

Paso 4. Probar un acceso físico denegado

1. La persona no autorizada presenta su tarjeta.
2. Seguridad Física registra DENEGADO y muestra LED rojo.
3. El analista de entrada anota la hora y confirma que no cruzó.
4. El responsable SOC verifica si es una prueba esperada o un incidente.
5. Para el ejercicio, abrir INC-001 y adjuntar lectura y video.
6. Solicitar revisión de UID/lista si el rechazo no era esperado.
7. Registrar respuesta y cierre con Auditoría.

No bloquear una cuenta corporativa solo porque una tarjeta fue rechazada una vez. Determinar qué control falló y qué acción corresponde.

Paso 5. Probar un permiso digital denegado

1. El auditor inicia sesión correctamente.
2. Intenta mantenimiento con el botón de la aplicación.
3. La aplicación devuelve 403 y registra DENEGADO.
4. SOC registra usuario, función y hora.
5. IAM confirma que lab_role=auditor no permite mantenimiento.
6. Auditoría registra que el control funcionó.

Ese rechazo es un resultado esperado de permisos; la autenticación sí fue correcta. Explicar ambas cosas por separado.

Paso 6. Responder a fallo de cámara o NVR

1. Identificar cámara que no muestra imagen o intervalo sin grabación.
2. Registrar hora de detección y periodo afectado conocido.
3. Seguridad Física comprueba alimentación, app abierta y URL.
4. TI comprueba red y dirección del teléfono.
5. En el NVR, el responsable ejecuta:

```
cd ~/lab-runtime/nvr
sudo docker compose ps
sudo docker compose logs --tail=100 frigate
df -h .
```

1. Tras corregir, SOC comprueba imagen y un archivo de grabación nuevo.
2. Registrar duración del corte. La recuperación no elimina el hueco de video.

Paso 7. Monitoreo desde teléfono

1. Preparar confianza del certificado según la guía de Seguridad Física.
2. Abrir NVR HTTPS en navegador móvil.
3. Usar cuenta de consulta y comprobar imagen de ambas cámaras.
4. Buscar un evento en History y reproducirlo.
5. Guardar evidencia de qué red usaba el móvil.

La interfaz web funciona como acceso móvil. Si el profesor exige una app instalada específica o acceso desde otra red, Dirección confirma ese alcance y TI prepara una solución compatible. Este paquete implementa acceso desde la red de laboratorio.

Paso 8. Turnos y continuidad

Asignar quién observa entrada, interior y registros durante cada periodo de prueba. Si hacen prueba de 24 horas, acordar revisiones y disponibilidad del operador; no mantener una persona despierta todo el periodo. El grabador debe continuar aunque la pantalla de SOC esté cerrada.

Registrar inicio/fin de cada revisión, cámaras disponibles, espacio, último segmento reproducible e incidentes abiertos. Finalizar cada turno dejando pendientes al siguiente responsable.

Entregan

Vista del hub, prueba móvil, reconstrucción del recorrido, INC-001 físico, prueba de rechazo digital y registro de continuidad. Cada evidencia lleva fecha, hora, fuente y responsable.

Referencias y videos

- Frigate: historial y grabaciones.
- Frigate: usuarios y permisos.
- Microsoft: registros de auditoría.
- OneLogin: eventos de aprovisionamiento.
- Video Frigate: instalación e interfaz: usar como orientación visual; los menús pueden cambiar.
- Video oficial OneLogin: ciclo de vida.